

TRINETRATICKET · TRINETRASIEM · LAB ENVIRONMENT

Phishing Investigation Workbook

5 New Incidents — TRQ-1006 through TRQ-1010

Full SOC analyst investigation flow: headers, external verification, SIEM correlation, evidence, closure

Instructor reference — contains resolutions. This workbook states each ticket's correct verdict and closing steps. Do not hand it to students before they've completed their own investigation — it defeats the exercise.

Trinetraa Cyber Academy · Prepared for the SOC Analyst Training Program lab environment

How to Investigate Any Phishing Ticket

This is the same seven-step flow a working SOC L1 analyst follows on every reported phishing email. Apply it to each of the five tickets in this workbook, then to the original five (TRQ-1001–TRQ-1005) using the same pattern.

- 1 Assign the ticket to yourself.** In TrinetraTicket, open **All Tickets** and click **Assign to Me** before you can add notes, escalate, or close it.
- 2 Read the report and the email header block.** The ticket's Reported Email panel shows From / To / Subject / Date, plus a collapsible **Email Headers** section with the full raw header block. Expand it and use the **Copy** button.
- 3 Verify authentication results externally.** Paste the raw headers into a real header analyzer (e.g. MXToolbox Email Header Analyzer, or Google's own header parser) and confirm SPF / DKIM / DMARC pass or fail, and whether the "From" domain matches the actual sending domain. Then take the sending IP from the headers (`X-Originating-IP` / `Received` line) and check its reputation on a real threat-intel tool — VirusTotal or AbuseIPDB both work well for this.
- 4 Read the subject and body for social-engineering markers.** Urgency language, requests to act outside normal process, mismatched sender identity vs. tone, generic greetings on a mass email — these support (but never replace) the technical evidence.
- 5 If a link is present, check it externally, then confirm scope in TrinetraSIEM.** Paste the URL into a real sandbox (urlscan.io or VirusTotal's URL scan both work without an account) to see what it actually loads. Then search TrinetraSIEM for that URL and for the sender to find every employee who received it, who clicked, and what HTTP status their click returned — `200` means the page was live and rendered; `404` means it was already taken down when they clicked.
- 6 If an attachment is present, do the same with its hash.** The ticket shows the file's SHA-256 with a **Search hash** shortcut into TrinetraSIEM. Check that same hash on VirusTotal (or detonate the file in a real sandbox like ANY.RUN or Hybrid Analysis if you have access) to see the real-world verdict, then use the SIEM search to find every other machine where that hash shows up.
- 7 Collect your evidence, write your notes, and close the ticket.** In Investigation Notes, summarize what you found (auth results, IP/domain reputation, who else was targeted, what happened when they clicked/opened). Pick the matching resolution and close — or Escalate if the case needs L2/IR involvement instead.

External tools referenced above (all free, no account required for basic use): MXToolbox Email Header Analyzer for headers · VirusTotal for IP / domain / URL / file-hash reputation · AbuseIPDB for IP reputation · urlscan.io for live URL sandboxing · ANY.RUN or Hybrid Analysis for attachment detonation. None of this data is built into TrinetraSIEM — that's intentional, so students practice pivoting between the internal SOC tooling and real-world OSINT tooling, exactly as they will on the job.

Password Expiration Notice Reported by Finance Manager

Meera Iyer (Finance) reported an automated IT password-expiration email as suspicious because of its urgent tone.

From	it-support@fakecorp-demo.com
Sending IP	10.10.5.12
Link	https://portal.fakecorp-demo.com/password-reset

STEP 3 — HEADERS

SPF, DKIM, and DMARC all **pass**, and the From domain (`fakecorp-demo.com`) matches the company's real domain exactly — no lookalike substitution. The sending IP, `10.10.5.12` , is a private RFC 1918 address: it can only originate from inside the corporate network, which real phishing infrastructure cannot do. There is nothing to look up externally here — a private IP has no public reputation to check, and that absence is itself the signal.

STEP 5 — LINK / SIEM

Run `ticket=TRQ-1006` in TrinetraSIEM. You'll find the identical notice delivered to four other employees across IT, Sales, Executive, and HR — consistent with a routine company-wide IT mailing, not a targeted attack. Meera's own click resolves with `status=200` to the real internal portal domain, followed by a normal, self-initiated password change with no location or device anomaly.

CLOSE AS

False Positive. Note in the ticket: verified sender domain and authentication all pass, sending IP is internal/private, link resolves to the legitimate internal portal, and four other employees received the identical routine notice.

Fake Document-Share Link Leads to Confirmed Credential Compromise

Rachel Kim (IT) reported a "document shared with you" email and wasn't sure whether she'd entered her password on the page it opened.

From	notifications@fakecorp-docshare-online.com
Sending IP	45.148.10.22
Link	http://fakecorp-docshare-online.com/view?doc=8827

STEP 3 — HEADERS

SPF, DKIM, and DMARC all **fail**. The domain `fakecorp-docshare-online.com` is not the company's real domain — it only contains "fakecorp" as a lookalike prefix. Checking `45.148.10.22` on VirusTotal/AbuseIPDB against real-world data for that range typically surfaces prior abuse reports for Netherlands-hosted VPS ranges used in phishing campaigns — a strong independent confirmation alongside the failed authentication.

STEP 5 — EXTERNAL SANDBOX

Paste `http://fakecorp-docshare-online.com/view?doc=8827` into urlscan.io or VirusTotal's URL scanner. For a live credential-harvesting page you'd expect to see a fake Microsoft/Google-style login form, a domain registered very recently, and no legitimate business presence behind it.

STEP 5 — SIEM CORRELATION

`ticket=TRQ-1007` shows this went to 5 employees. `sourcetype=NETWORK ticket=TRQ-1007` shows Rachel Kim's click at `status=200` (page was live), followed one minute later by `sourcetype=AUTHENTICATION recipient=rachel.kim@fakecorp-demo.com` — a successful sign-in from the **same IP that sent the phishing email**, using password-only auth with `mfa_status=NOT_ENROLLED`. That's a confirmed, complete account takeover. James Patel also loaded the live page (`200`) but didn't enter anything. Linda Martinez clicked hours later and got `404` — the infrastructure was already down by then.

- Failed SPF/DKIM/DMARC on a lookalike domain
- Confirmed successful sign-in for Rachel Kim from the sender's own IP, no MFA
- 5 total recipients; 2 clicked, 1 confirmed compromised, 1 clicked after takedown

CLOSE AS

Confirmed Malicious – Escalated to IR. A real account compromise with no MFA protecting it needs a forced password reset and session revocation beyond what a single analyst closes out alone — use **Escalate**, not Close, for this one.

Unfamiliar Vendor Newsletter Reported by CFO

Angela Foster (CFO) reported a product-update newsletter from a budgeting tool the company subscribes to, because she didn't personally recognize the sender.

From	newsletter@realbudgetsoft-demo.com
Sending IP	52.14.22.8
Link	https://realbudgetsoft-demo.com/blog/march-release

STEP 3 — HEADERS

SPF, DKIM, and DMARC all **pass** for `realbudgetsoft-demo.com` — and critically, the From domain, the link domain, and the DMARC-aligned domain are all the *same* real vendor domain, not a fakecorp lookalike. This isn't spoofing the company itself; it's genuine mail from a third party the company does business with. A WHOIS/company lookup on `realbudgetsoft-demo.com` confirms it's an established, real SaaS vendor domain, not a fresh registration.

STEP 5 — LINK / SIEM

`ticket=TRQ-1008` shows only 2 recipients (Angela Foster and CEO Michael Ross) — consistent with a product-update subscription list, not a mass spray campaign. Angela's click resolves at `status=200` to the vendor's own blog, with no follow-on authentication event.

CLOSE AS

False Positive. Note in the ticket: sender authentication passes and is domain-aligned to a known, legitimate vendor; recipient list matches a subscription pattern, not a phishing spray; link resolves to the vendor's own content with no credential prompt.

Fake E-Signature Request Leads to Malware Execution

Karan Mehta (Sales) reported an email asking him to review and sign a contract, either via a link or an attached preview copy. He downloaded the attachment after the link looked wrong.

From	esign-notify@fakecorp-esignature-verify.com
Sending IP	185.220.102.15
Link	http://fakecorp-esignature-verify.com/sign/77452
Attachment	Contract_77452_Preview.pdf
SHA-256	c4e8b0d29a1f63578d2a6c0e4f81b3d5047c9e1b3a5d7f6082c4e6a80d2f4b6e

STEP 3 — HEADERS

SPF, DKIM, and DMARC all **fail**. `fakecorp-esignature-verify.com` is a lookalike, not the real company domain. The sending IP, `185.220.102.15`, sits in the same address block family as the IP behind TRQ-1001's credential-harvesting campaign — worth flagging in your notes as a possible shared-infrastructure link across incidents, even though this workbook treats them as separate tickets.

STEP 5/6 — EXTERNAL CHECKS

The link, checked in a sandbox, should show a fake e-signature/login page. Independently, take the SHA-256 above to VirusTotal's file-hash lookup (or detonate a matching sample in ANY.RUN/Hybrid Analysis) — for a script-dropper PDF like this you'd expect multiple AV engines to flag it and a sandbox report showing a script host process spawned from the PDF reader.

STEP 6 — SIEM CORRELATION

`hash=c4e8b0d29a1f6357` in TrinetraSIEM surfaces the full chain on Karan Mehta's machine: the PDF reader spawning `wscript.exe`, followed by an outbound connection to `185.220.102.31` flagged as C2 infrastructure. Note that `sourcetype=NETWORK ticket=TRQ-1009` shows Karan's own click on the *link* returned `status=200` but he didn't submit anything there — he was compromised through the *attachment* instead, not the link. Alex Johnson clicked the same link later and got `404` (post-takedown) — he shows no attachment activity at all, so he's clean despite receiving the identical campaign.

- Failed SPF/DKIM/DMARC on a lookalike domain, IP related to a known campaign family
- Confirmed malware execution chain on Karan Mehta's workstation via the attachment (not the link)
- C2 beacon to external infrastructure immediately following execution
- 5 recipients total; only Karan compromised, one other clicked the link post-takedown with no further impact

CLOSE AS

Confirmed Malicious – Escalated to IR. Active C2 beaconing on a workstation requires isolation and IR handling, not a same-tier close.

Automated VPN Certificate Renewal Notice Reported by Recruiter

David Okafor (HR) reported a terse, automated-sounding VPN certificate renewal notice as suspicious.

From	vpn-automation@fakecorp-demo.com
Sending IP	10.10.5.40
Link	https://vpn.fakecorp-demo.com/renew

STEP 3 — HEADERS

SPF, DKIM, and DMARC all **pass** on the real `fakecorp-demo.com` domain. The sending IP `10.10.5.40` is again a private, internal address — consistent with an automated internal mailer, not external phishing infrastructure. The terse, "robotic" tone that made David suspicious is actually typical and expected for genuine automated system mail; tone alone is never sufficient evidence either way.

STEP 5 — LINK / SIEM

`ticket=TRQ-1010` shows the identical notice sent to three other employees (Finance, IT, HR) — a routine automated mailing pattern, not a targeted spray. David's click resolves at `status=200` to the real internal VPN domain, with no follow-on anomaly.

CLOSE AS

False Positive. Note in the ticket: sender authentication passes on the real internal domain, sending IP is internal/private, link resolves to the legitimate internal VPN portal, and the recipient pattern matches routine automated IT communication.